STRIDE ISP 4.1 – PR.AA

Identity Management, Authentication and Access Control

Version [2.0]

Purpose:

This document defines the Stride standards related to Identity Management, Authentication, and Access Control.

Scope and Applicability

These policies and standards apply to all Stride-owned technology and business operations.

All workforce members and their respective facilities supporting Stride business operations, technology, or both, wherever Stride data is stored or processed, including any third party contracted by Stride to handle, process, transmit, store, or dispose of Stride data are subject to the requirements of this document.

All data, systems, activities, and assets owned, leased, controlled, or used by Stride, its agents, contractors, or other business partners on behalf of Stride are within the scope of the requirements of this document.

The requirements outlined in this document apply where technically feasible and commercially reasonable, as determined by executive management. Any exceptions to these standards must be requested using the approved workflow and remain documented until compliance has been achieved. Exceptions are only granted temporarily for periods of up to one calendar year.

Definitions

All definitions are located within Stride - ISP 1.2 – IT Policy Definitions.

Any inquiries regarding terminology or clarity may be directed to Stride's Information Security Team for assistance.

Publication Owners

Johnny Burns – Point of Contact, Content Coordinator & Author

Jen Havenner – Business Owner

Mark Williams – Executive Sponsor

Document Control

This document may contain proprietary, confidential, or sensitive information owned wholly by Stride Inc. Any distribution of the information contained within this document, in whole or in part, outside of Stride or its subsidiary entities requires the approval of the Executive Sponsor.

This document will be reviewed at least annually and re-issued when revisions are necessary. Any changes introduced in the most recent version are itemized below. Obsolete copies should be destroyed or archived upon the release of the newest version.

Implementation and Compliance

All business units are required to comply with any changes applied to the most recent version of this publication within 90 days from the date of publication.

Change History

Version	Date of Change	Summary of Change(s)
1.0	6/15/2022	Initial Release and Publication
1.1	12/01/2022	- Added Change History - Updated and/or redacted language for clarity where necessary
1.2	03/17/2023	- Updated approvals section
1.3	12/04/2023	- Overhaul of PR.AC-1 language, aligning with SOX requirements - Reformatting and migration to a standardized template - Corrected Exception Request workflow within the Scope and Applicability section
1.3	12/20/2023	- Updated PR.AC-1 to include: - Contractor Extension requirements - Workforce Transfers and Reassignments - SOW/IQN Contractor Extension requirements added
2.0	01/30/2025	- Updated Policy Title - Updated Policy to match NIST 2.0 Release Changes - Updated Publication Owners - Updated Service/Break Glass/Emergency Access Accounts
2.0	03/08/2025	- Published

IDENTITY MANAGEMENT, AUTHENTICATION AND ACCESS CONTROL (PR.AA) STANDARDS

Stride Policy on Identity Management, Authentication and Access Control:

Access to physical and logical assets is limited to authorized users, services, and hardware managed commensurate with the assessed risk of unauthorized access.

PR.AA-01: IDENTITY AND CREDENTIAL MANAGEMENT

Identities and credentials for authorized users, services, and hardware are managed by the organization.

Standards:

- Stride creates, manages, and revokes identities and access to workforce members across the organization. These identities and accesses are monitored and periodically audited.

- Identity Governance activities are conducted by the members of the Identity Governance Team, the overarching responsibilities of the Identity Governance Team may include, but are not limited to:

    - Delegation of identity and access control tasks to members of the Identity Operations Team.

    - Ensuring identity access and management practices are conducted by qualified IT personnel.

    - Enforcing appropriate identity and access management processes and procedures across the organization.

New Access

- New account requests and access change requests are verified and require management approval in accordance with the request.

- New access or changes to access are granted in alignment with the level of access requested, and access granted is based on the principle of least privilege.

- Records are maintained showing new account requests, changes to existing accounts, and terminations and/or revocations of access.

- All accounts must be uniquely named.

- Where possible a standardized approach to naming convention should be observed in the format of the first letter of the first name followed by full last name:
    - e.g., John Smith = jsmith@k12.com
- Otherwise, system specific naming conventions should be observed:
    - e.g., svc-webapp-prod
- If multiple accounts are required, provide consecutive identifiers:
    - e.g., svc-webapp-prod-01 and svc-webapp-prod-02

Workforce Transfers or Reassignment

- Workforce members' access to systems and applications is reviewed upon transfer or reassignment to a different role within Stride.
- Access reviews will occur within fifteen (15) days following the completed transfer or reassignment.
- At times, transfers and reassignments may take longer than the allotted fifteen (15) days, in this case, the receiving manager of the workforce member will maintain a documented plan showing the intended date of separation from the previous role.
- This plan must be shared with the previous manager of the workforce member.
- The plan must be updated for accuracy should the proposed separation date be exceeded.

Administrative Access

- Administrative privileges are limited to authorized individuals who support the applications, end-users, or systems.
- Administrators of systems and applications utilize administrative accounts when required for essential job functions.
- Administrators are granted a non-privileged (normal user) role for use when administrative privileges are not required to carry out job functions.

Service/Breakglass/Emergency Access Accounts/Non-Human Accounts

- All Service, Break Glass, and Emergency Access Accounts should use a secure storage vault solution, where technically feasible.
- Strict access controls for secure storage vaults are implemented with only authorized personnel maintaining access.
- Multifactor Authentication must be utilized when accessing vaults.
- Continuous monitoring is implemented for all accounts and associated credentials for misuse or compromise.
- Credentials should not be hardcoded, written, or configured in applications or files.
- Accounts must be created following the system-specific naming convention:
    - e.g., svc-webapp-prod or svc-webapp-prod-01 and svc-webapp-prod-02

Contractor and Tenant Member Access Extensions

- Access extensions may be required to permit workforce members classified as contractors access to Stride systems and applications.
    - Access extensions may not extend more than 60 days from the intended expiration date of the SOW Contract.
    - Access extensions may not extend more than 90 days from the intended expiration date of the IQN Contract or Tenant Member Access.

User Access Reviews (UARS)

- User access is periodically reviewed and documented.
- Access reviews are performed by IT and business owners at least annually.
- Access revocations prompted by User Access Reviews are performed within 30 business days of the completion of the review.

Segregation of Duties

- Duties of individuals are separated as required to prevent malicious or otherwise unauthorized activities, where technically feasible.

- Segregation of Duties is documented where required, to include a breakdown of roles and related access levels.

- Where technically feasible and determined as a requirement, Segregation of Duties is enforced through assigned system access authorizations.

Access Deprovisioning and Termination

- Access de-provisioning and terminations are carried out by the Identity Operations Team or by a team delegated such responsibility.

- Upon notification a workforce member's access shall be revoked, disabled, and/or terminated as follows:

    - 1 business day for Immediate (also known as ASAP) terminations upon receipt of an Immediate termination notification.

    - 3 business days for non-ASAP terminations upon receipt of a non-ASAP termination notification.

STRIDE PASSWORD STANDARD		
Stride employs a default preference of Multi-Factor Authentication (MFA), where technically feasible. The requirements outlined in this table describe the password standards for both Non-MFA accounts and MFA accounts.		
	NON-MFA System Password Requirements:	**MFA-Enabled System Password Requirements:**
Length	Passwords must be a minimum of eight (8) characters	
Complexity	Cannot contain User ID, Username, or derivative of personal identity Requires the use of 3 of 4 complexity categories: Uppercase Characters (A, B, C, etc.) Lowercase Characters (a, b, c, etc.) Numeric Digits (1, 2, 3, etc.) Special Characters (!, % , $, etc.)	
Reuse	Reuse is disallowed OR limited for a specified number of generations	Reuse is disallowed OR limited for a specified number of generations

Lockout	Users are limited to 5 unsuccessful login attempts	Users are limited to 5 unsuccessful login attempts
Password Expiration	Passwords do not expire.	Passwords do not expire.
MFA Re-Authentication	Not Applicable	Stride Owned Device: 72 Hours Personally Owned Device: 24 Hours
Banned Password List	Not Applicable	Enabled with custom Stride word list, where possible ****See Note****
Password Protection	All passwords will be stored and transmitted using cryptographically protected mechanisms Obfuscation of authentication information is enforced on systems and applications capable of obfuscation	

Managed or Automated Identities and Credentials

- Identities and credentials for authorized users, services, and hardware are actively managed and automated by the organization.
- Default credentials proved by manufacturers (e.g., “admin/admin”) are changed to secure ones to prevent unauthorized access.
- Password policies are established to ensure users create strong, complex passwords that are harder to crack, requiring a mix of uppercase, lowercase, numbers, and special characters.
- Access is automatically revoked under defined conditions:
    - When an employee leaves the organization.
    - If an account is inactive for a defined period of time.
    - When a security compromise is detected.
- Asset owners (managers responsible for systems or data) periodically review who has access to their resources to ensure:
    - Only authorized users retain access.
    - Access aligns with current roles and responsibilities.

Physical and Logical Access to Systems

- Ensure only authorized individuals can enter physical spaces containing sensitive equipment (e.g., server rooms, data centers).
- Access is controlled with ID badges, biometrics, or PIN codes.
- Electronic access to systems, applications, or data requires:
    - Authentication: Usernames, passwords, multi-factor authentication.
    - Authorization: Permissions granted based on job roles.
- Access is granted only if required to perform their job, following the principle of least privilege.
- Users are trained in security policies and safe practices before gaining access.
- Activities are monitored (e.g., audit logs, alerts) to detect and respond to misuse or suspicious behavior.
- Identities and credentials for authorized devices and users are actively managed or automated, which includes:
    - Removal of default and factory passwords.
    - Password strength requirements.
    - Automatic revocation of credentials under defined conditions.
    - Regular asset owner access reviews.

References:

- STRIDE ISP 1.2 – IT Security Policy Definitions
- Additional guidance for Access Control and Account Management may be located in NIST SP 800-171 and SP 800-210
- CIS Controls v8.0: 5.1
- CIS Controls v8.0: 6.7

- CRI Profile v2.0: PR.AA-01
- CRI Profile v2.0: PR.AA-01.01
- CRI Profile v2.0: PR.AA-01.02
- CSF v1.1: PR.AC-1

PR.AA-02: IDENTITY BINDING TO CREDENTIALS

Identities are proofed and bound to credentials based on the context of interactions.

Standards:

Stride assigns unique identities to users, enabling secure access to organizational systems and ensuring interactions can be precisely traced back to the individual. These identities are fundamental to maintaining accountability, transparency, and a robust access management framework.

- MFA is required, where technically feasible, for all externally exposed applications, remote network access, and all administrative access. This additional layer of protection significantly reduces risks associated with compromised credentials and unauthorized access.

- Stride authenticates a user's identity before granting system access. This ensures that only authorized individuals can interact with critical systems and data.

- Authorization levels are validated before granting access, ensuring users can only access resources necessary for their role (principle of least privilege). This minimizes excessive permissions and reduces potential attack vectors.

- Each account is assigned to a single individual, prohibiting shared accounts. This guarantees all system activities are clearly attributed to a specific user, facilitating accurate monitoring and auditing.

- All user activities, including login attempts, system interactions, and access changes, are logged comprehensively. These logs are actively monitored and reviewed to detect anomalies, track unauthorized activities, and maintain compliance with organizational policies and regulatory requirements.

References:

- Additional guidance can be obtained from NIST SP 800-63-3 – Digital Identity Guidelines
- CRI Profile v2.0: PR.AA-02
- CRI Profile v2.0: PR.AA-02.01
- CSF v1.1: PR.AC-6

PR.AA-03: AUTHENTICATION

Users, services, and hardware are authenticated before accessing organizational systems.

Standards:

- Identities are used to uniquely identify and authenticate organizational users and associate the identity with processes acting on behalf of the user.
- Authentication requirements are defined and implemented based on the risk level of user access or specific transactions.
- Decisions to authorize user access to devices and other assets consider:
    - Business need for access.
    - The data access type (e.g., customer PII, public data).
    - The risk of the transaction (e.g., internal-to-internal, external-to-internal).
    - The organization's level of trust for the accessing agent (e.g., external application, internal user).
    - Potential harm from unauthorized access.
- The organization reduces fraudulent activity and protects reputational integrity through:
    - email verification mechanisms (e.g., DMARC, DKIM).
    - Call-back verification.

    - Secure file exchange facilities.
    - Out-of-band communications.
    - Customer outreach and education thwart imposters and fraudsters.
- Stride manages all remote access processes and technologies, except for external communication platforms such as email, instant messaging, and meeting platforms.
    - Virtual Private Networks (VPNs) are employed to securely extend a host/network by tunneling through public or private networks.
    - Remote access is routed via managed access control points.
    - Remote execution of privileged commands and remote access to information requires authorization.
    - Remote access connections are terminated at the end of sessions or after a defined period of inactivity.
- Remote access processes and requirements are reviewed at least annually.

References:

- NIST SP 800-63-3 – Digital Identity Guidelines
- CRI Profile v2.0: PR.AA-04
- CRI Profile v2.0: PR.AA-04.01

PR.AA-04: IDENTITY ASSERTIONS

Identities are asserted and verified to ensure that interactions with organizational systems and data are conducted by authenticated and authorized users.

Standards:

Identities are asserted and verified before granting access to organizational systems, dates, and applications.

- Use digital certifications, identity tokes, and federated identity management systems for identity verification.

- Implement multi-factor authentication (MFA), contextual authentication, behavioral analysis, and adaptive authentication based on the risk level of access or transaction.

- Utilize directory services like Active Directory for centralized identity management.

- Ensure consistency of identity information across all systems through directory synchronization.

- Implement Single Sign-On (SSO) to allow single authentication for multiple applications.

- Use federated access solutions with standards like SAML and OpenID Connect for secure external collaborations.

- Facilitate seamless access between modern systems and legacy applications through credential mapping.

- Consider business need, data type, transaction risk, trust level, and potential harm in access authorization decisions.

- Protect credentials and authorization artifacts through encryption during transmission and at rest.

- Maintain and actively monitor comprehensive audit logs of authentication and authorization events.

- Reduce fraudulent activity and protect reputation through email verification mechanisms, call-back verification, secure file exchanges, and customer outreach.

- Manage remote access securely, using cryptography, VPNs, managed access control points, and terminating sessions after inactivity.

- Review remote access processes and requirements annually.

- Provide training on secure identity practices, safeguarding credentials, and recognizing phishing attempts.

References:

- CRI Profile v2.0: PR.AA-04

- CRI Profile v2.0: PR.AA-04.01

PR.AA-05: ACCESS AUTHORIZATIONS

Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties.

Standards:

- Access rights are granted only to the minimum level required for users, processes, and systems to fulfill essential job responsibilities.
- System access is limited to authorized users, processes acting on behalf of authorized users, devices, types of transactions, and functions that authorized users are permitted to execute.
- Access reviews are completed at least annually to ensure compliance with the least privilege principle.
- Permissions and entitlements are reviewed to ensure they remain appropriate, aligned with role requirements, and adhere to policy.
- Critical processes are structured so that no single individual can initiate and approve high-risk actions, reducing the potential for misuse or error.
- Access privileges consider the separation of duties through role-based access control and asset owner access recertification.
- Elevated privileges are strictly managed, incorporating multi-factor authentication (MFA), dual accounts, session time constraints, and continuous monitoring.
- Staff and services with elevated system entitlements are strictly limited and closely managed.
- Service accounts undergo strict oversight, including secure credential handling, regular ownership reviews, and proactive monitoring to detect unauthorized or malicious use.
- Controls over service account lifecycles ensure strict security over creation, use, and termination; no embedded passwords in code; frequent reviews of account ownership; visibility for unauthorized use; and hardening against malicious insider use.

References:

- SP 800-218: PO.5.2
- SP 800-218: PS.1.1
- CIS Controls v8.0: 3.3
- CIS Controls v8.0: 6.8
- CRI Profile v2.0: PR.AA-05
- CRI Profile v2.0: PR.AA-05.01
- CRI Profile v2.0: PR.AA-05.02
- CRI Profile v2.0: PR.AA-05.03
- CRI Profile v2.0: PR.AA-05.04
- CSF v1.1: PR.AC-1
- CSF v1.1: PR.AC-3
- CSF v1.1: PR.AC-4

PR.AA-06: PHYSICAL ACCESS

Physical access to assets is managed, monitored, and enforced commensurate with risk.

Standards:

- Limit physical access to organizational systems, equipment, and the respective operating environments to authorized individuals.
- Protect and monitor the physical facility and support infrastructure for organizational systems.
- Escort visitors and monitor visitor activity.
- Maintain logs of all physical access.

- Manage, protect, and log physical access to sensitive areas, devices, consoles, equipment, and network cabling and infrastructure.
- Manage and protect physical and visual access to sensitive information assets and physical records (e.g., session lockout, clean desk policies, printers/facsimile output trays, file cabinet/room security, and document labeling).
- Authorize wireless access before allowing connections.
- Protect wireless access using authentication and encryption.
- Monitor, control, and protect communications at the external and key internal boundaries of organizational systems.
- Employ architectural designs, software development techniques, and systems engineering principles to promote effective information security.
- Implement subnetworks or cloud equivalent architecture for publicly accessible system components, separate from internal networks.
- Deny network communications traffic by default and allow traffic by exception (deny all, permit by exception).
- Protect the authenticity of communication sessions.

References:

- SP 800-218: PO.5.2
- CRI Profile v2.0: PR.AA-06
- CRI Profile v2.0: PR.AA-06.01
- CRI Profile v2.0: PR.AA-06.02
- CSF v1.1: PR.AC-2
- CSF v1.1: PR.PT-4